

# INTRODUCCIÓN A LA FORENSIA DIGITAL

# CUERPO DOCENTE

- Prof:
  - Einar Lanfranco ([einar@info.unlp.edu.ar](mailto:einar@info.unlp.edu.ar))
- JTPs:
  - Sandra Zilla ([szilla@info.unlp.edu.ar](mailto:szilla@info.unlp.edu.ar))

# HORARIOS:

- Teoría: Jueves 18:30 a 20:30 (híbrido)
- Plataforma Moodle a través de <https://catedras.info.unlp.edu.ar>

# LA METODOLOGÍA:

- Desarrollo de un trabajo integrador
- Entrega de prácticas y actividades
- Evaluaciones parciales on-line: no necesariamente múltiple choice.
- CTF (Capture The Flag).
- Asistencia a clase opcional, excepto días de evaluación y exposición.
- Entrega Final del trabajo integrador con exposición



## ¿CÓMO APROBAR LA CURSADA?

- La materia estará dividida en prácticas entregables y una parte teórica evaluada con coloquios.
- Tanto las prácticas como los coloquios se aprueban con **nota mayor a 4**.
- Para aprobar la materia no debe haber ni prácticas ni coloquios desaprobados.
- La nota de la cursada está compuesta por el **60% de la nota práctica + 40% de la nota teórica**.
- La nota final será el promedio de la nota de la cursada con la nota del trabajo integrador.
- La cursada se aprueba con una nota final mayor o igual a 4.

## RÉGIMEN DE EXAMEN FINAL:

- La nota de final de la materia se compone de la nota de la cursada más un trabajo integrador a desarrollar que consistirá en la automatización de algunas de las etapas de la forensia digital aplicado a ejercicios de CTF.
- Nota de final = Nota de final de cursada  $\pm$  2 de acuerdo al trabajo final

# CTF

- Un CTF es una competición que permite poner a prueba habilidades sobre hacking por medio de diferentes tipos de desafíos.
- Resolver cada uno de estos desafíos llegaremos a una **flag**, que suele ser una cadena de caracteres con un formato específico como **FLAG{W3lc0m3\_t0\_CTF}**.
- La flag permite confirmar a la plataforma de la competición que hemos sido capaces de resolver el reto y normalmente, va acompañada de una compensación con puntos.

# CTF: TIPOS DE CTF

- **Jeopardy:** Retos de diferentes temáticas (Crypto, Web, Forense, Reversing, Exploiting...) donde se ganan puntos cuando son resueltos según el nivel de dificultad.
- **Attack-Defense:** Cada equipo tiene un servidor o una red de equipos con vulnerabilidades que deben de proteger mientras que intentan conseguir acceso al equipo contrario.
  - En este reto hay puntos de ataque y puntos de defensa.

## CTF: IFD

- Utilizaremos una plataforma de CTF tipo Jeopardy y la competición será en grupos.
- Las prácticas estarán compuestas, en parte, por desafíos obligatorios del CTF.
- Además habrá desafíos extras con dificultades variadas, entre ellos desafíos creados por alumnos de años anteriores.

# CTF: UNLP

- Tenemos un equipo de CTF llamado SYPER y compuesto de docentes y alumnos de la facultad.
- Competimos en CTF nacionales e internacionales.
  - <https://ctftime.org/team/2003>
  - <https://www.info.unlp.edu.ar/docentes-de-informatica-ganaron-el-ctf-de-la-ekoparty/>

## SISTEMA SEGURO:

"El único sistema seguro es aquel que está apagado, desconectado, dentro de una caja fuerte de titanio, enterrado en un bunker de concreto, rodeado de gas tóxico y vigilado por guardias armados y muy bien pagados. Y aún así, no apostaría mi vida a que es seguro".

Gene Spafford - Analista virus Morris

[http://en.wikipedia.org/wiki/Gene\\_Spafford](http://en.wikipedia.org/wiki/Gene_Spafford)

# INSEGURIDAD INFORMÁTICA

- La inseguridad informática es el conjunto de riesgos a los cuales están expuestos los recursos informáticos.
- Estos riesgos son muchos y muy variados: virus y gusanos, spyware, ransomware, malware, ataques de denegación de servicio, accesos no autorizados, modificación de los sistemas, robos de información, etc.



# INTRODUCCIÓN A LA FORENSIA DIGITAL

- El análisis forense en un sistema informático es una ciencia moderna que permite reconstruir lo que ha sucedido en un sistema tras un incidente de seguridad.
- Puede determinar quién, desde dónde, cómo, cuándo y qué acciones ha llevado a cabo un usuario o intruso en los sistemas afectados por un evento de seguridad.

# IFD: EL PROCESO FORENSE

- La naturaleza de la evidencia digital es tal que posee desafíos para su admisibilidad en procesos legales.
- Para hacer frente a estos desafíos, hay que seguir procesos forenses adecuados.
- Estos procesos se componen básicamente de 4 fases:
  1. Recolección
  2. Examinación/Extracción
  3. Análisis
  4. Reporte

# COLONIAL PIPELINE 2021

- El ciberataque de Colonial Pipeline tuvo lugar entre el jueves 6 de mayo y el viernes 7 de mayo de 2021
- Cuando Colonial Pipeline sufrió un ataque de malware que los obligó a cerrar su sistema.
  1. El ataque detuvo todas las operaciones del oleoducto.
  2. Colonial Pipeline dijo que el ataque afectó a algunos de sus sistemas de información. El presidente Joe Biden declaró el estado de emergencia el domingo 9 de mayo.
  3. Fue «lo que se cree que es el mayor ciberataque exitoso a la infraestructura petrolera en la historia del país» y una fuente le dijo que el ataque fue llevado a cabo por una empresa criminal de ransomware llamada DarkSide, y no por un gobierno extranjero.
  4. Se cree que el mismo grupo robó 100 gigabytes de datos de los servidores de la empresa el día antes del ataque de malware.



# COLONIAL PIPELINE 2021

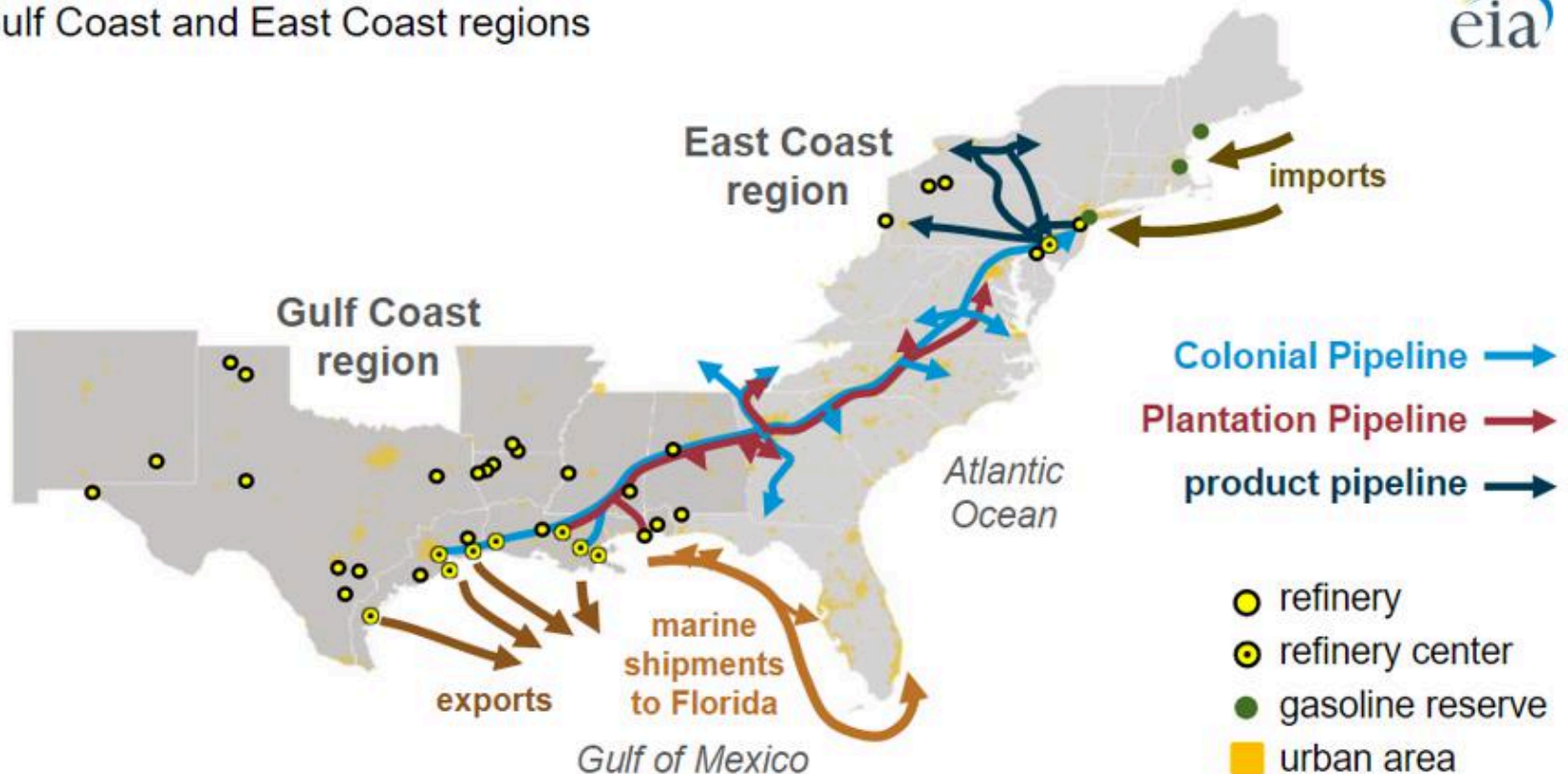


© AP



# COLONIAL PIPELINE 2021

## Petroleum product supply overview U.S. Gulf Coast and East Coast regions



Source: U.S. Energy Information Administration, [East Coast and Gulf Coast Transportation Fuels Markets](#)

Note: Map updated to reflect changes in U.S. refineries since initial report.

# A QUIÉN PERSIGUEN?

The New York Times

## *The F.B.I. confirms that DarkSide, a ransomware group, was behind the hack of a major U.S. pipeline.*

A deputy national security adviser said that the government believed DarkSide was “a criminal actor” but was looking for any ties to nation-states.



Share full article



177



**DarkSide hackers say the Colonial Pipeline cyber attack was only about the money — not politics**

# CRONOLOGÍA DEL ATAQUE Y LA RESPUESTA

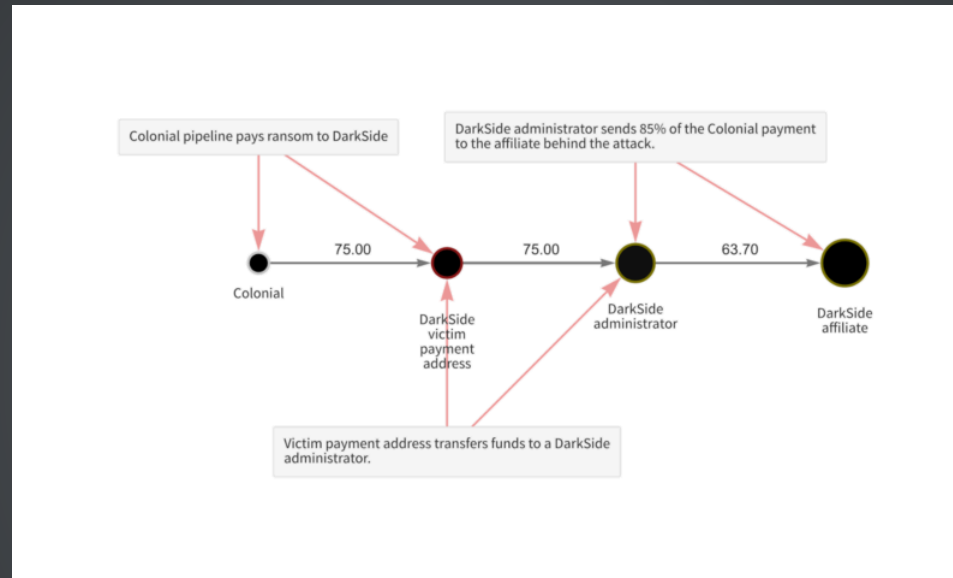
- Mayo 2021: Colonial Pipeline sufre un ataque de ransomware de DarkSide.
- La empresa paga 75 BTC (~4.4 millones USD en ese momento) a los atacantes.
- El ataque causa interrupción del suministro de combustible, lo que genera escasez y pánico en varias regiones de EE. UU.
- Seis días después, Colonial reanuda operaciones.
- Un mes después: el Departamento de Justicia (DoJ) anuncia la recuperación de \$2.3 millones en BTC (parte del pago original).
- [URL](#)

# MODELO RANSOMWARE-AS-A-SERVICE (RAAS)

- DarkSide provee la infraestructura y el malware a “afiliados”.
- Los afiliados ejecutan el ataque en la víctima.
- Los administradores se quedan con una comisión del rescate.
- Ventaja para los atacantes: escalabilidad y anonimato en la distribución de funciones.
- Desventaja para las víctimas: aumenta el número de grupos capaces de lanzar ataques complejos.

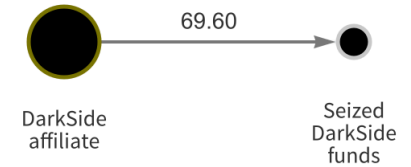
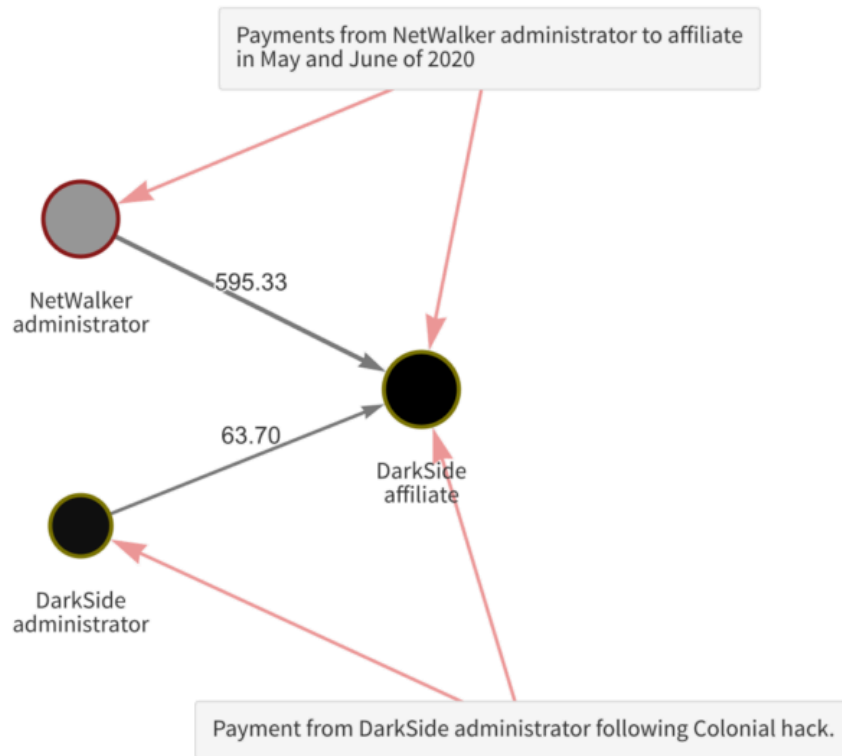


# LA FORENSIA - FOLLOW THE MONEY



- Colonial → Dirección de los atacantes: 75 BTC.
- Atacantes → Administradores de DarkSide: Los administradores retienen un 15% (~11.3 BTC).
- Administradores → Afiliado (ejecutor del ataque): 63.7 BTC (≈ 85%).
- FBI logra rastrear y confiscar fondos del afiliado el 28 de mayo de 2021.

# LA FORENSIA - FOLLOW THE MONEY



# EL RASTRO -> RECUPERANDO 63.7/75 BITCOINS

- An affidavit filed on Monday said the FBI was in possession of a private key to unlock a bitcoin wallet that had received most of the funds. It was unclear how the FBI gained access to the key.

# EL FBI ARRESTÓ A UNA CONTRATISTA DE LA NSA (2017)

- El FBI arrestó a una contratista de la NSA de 25 años por filtrar información al diario The Intercept sobre los ataques rusos a las empresas de máquinas de votación



# EL FBI ARRESTÓ A UNA CONTRATISTA DE LA NSA

- La agarraron mediante una forensia rara
  - The Intercept envía el documento a la NSA para verificar y darles lugar a comentarios: **tengo esto! que tenes para decir?**
  - El documento resulta ser un scanning de una impresión
    - Se supone que hizo esto para evitar metadatos del archivo



# EL FBI ARRESTÓ A UNA CONTRATISTA DE LA NSA

- Pero, por desgracia para ella, parece que no era consciente del hecho de que:
  - la mayoría de las nuevas impresoras imprimen puntos amarillos casi invisibles que registran exactamente cuándo y dónde se imprime cualquier documento

# EL FBI ARRESTÓ A UNA CONTRATISTA DE LA NSA

- Información en ese documento permite saber:
  - la impresora que lo imprimió
  - el horario
  - Cruzándolo con los datos de los usuarios en los equipos
- Link: <http://thehackernews.com/2017/06/nsa-russian-hacking-leak.html>

# MANCHAS INVISIBLES

EFF: DocuColor Tracking Dot

← → ↻ ⌂ ⓘ <https://w2.eff.org/Privacy/printers/docucolor...>

substitute.

col parity 1 2 3 4 5 6 7 8 9 10 11 12 13 14 15

64

32

16

8

4

2

1

Clear Submit

### DocuColor pattern interpretation

This is an interpretation of the following dot pattern:

```
      111111
123456789012345
7 000 00000 0 000
6      0
5 0      0 00 0
4 00      0 000000
3 0      0 00 0
2 0 0 0 00 0000
1 0 00 000 0
0      00000 00
```

This interpretation is based on reverse engineering, and may current for every DocuColor model version. Xerox Corpora with this program, and does not warrant its correctness.

Row and column parity verified correctly.

Printer serial number: 535218 [or 29535218]

Date: May 9, 2017

Time: 06:20

- "The document leaked by the Intercept was from a printer with model number 54, serial number 29535218. The document was printed on May 9, 2017, at 6:20. The NSA almost certainly has a record of who used the printer at that time."

# RESULTADO DE LA PERICIA



# EL CASO DEL "PASILLO" Y EL BOLETÍN FANTASMA DE AFA

- Noviembre 2025: Estudiantes de La Plata no le hizo el tradicional "pasillo" de reconocimiento a Rosario Central, ya que el título que le dieron a Central fue inventado e indigno al mundo del futbol.
- Alguien se enojó y AFA anunció que iba a sancionar a Estudiantes, invocando una obligación reglamentaria de hacer el pasillo.
- La norma citada: el **Boletín de Resoluciones N° 6625**, supuestamente publicado el **12 de febrero de 2025**, meses antes del partido.
- El PDF se llamaba "**Boletín-Resoluciones-6625-(12-02-2025).pdf**".

## CÓMO SE "RECUPERÓ" EL ARCHIVO: WAYBACK MACHINE

- Ante las sospechas, se recurrió al Internet Archive / Wayback Machine, que guarda copias históricas de la web de AFA.
- Resultado: al **15 de marzo de 2025** (un mes después de la supuesta publicación) el Boletín 6625 **no existía** en la web oficial de AFA.
- Además, la numeración de boletines mostraba saltos irregulares alrededor de ese número.
- Se lo comparó con el **Boletín 6627**, publicado el 13/02/2025, cuyos metadatos sí eran coherentes con su fecha (creado el 14/02/2025).



# LA CLAVE: LOS METADATOS DEL PDF

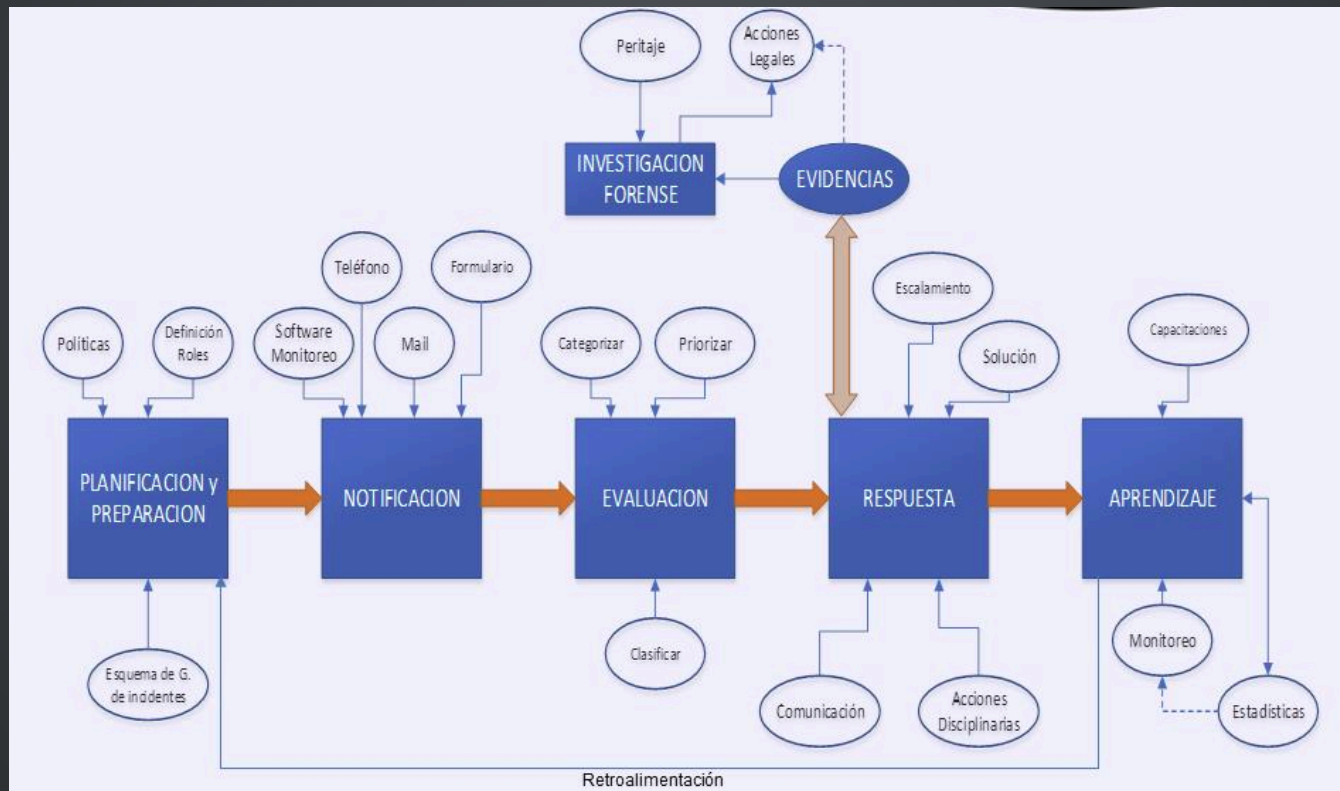
- El archivo del Boletín 6625 tenía en sus **propiedades del documento** (metadatos: fecha de creación y de modificación) un dato que lo delataba.
- Metadatos: creado y modificado el **domingo 23 de noviembre de 2025 a las 19:21 hs.**
- Ese horario coincide con el **final del partido Estudiantes-Central en Rosario**, no con febrero de 2025.
- Otro dato incriminatorio en los mismos metadatos: el campo "Producer/Creator" indicaba que el PDF se había generado con **Acrobat PS Maker 25**, una versión de software que salió al mercado recién el **4 de marzo de 2025** — es decir, **posterior** a la fecha del 12/02/2025 que el boletín dice tener.
- Eso hace imposible que el archivo, tal como está, haya sido creado en la fecha que la AFA sostiene: la herramienta que lo generó todavía no existía en esa fecha.
- Conclusión que se desprende de la evidencia: el documento habría sido redactado/generado **después del hecho** que decía regular, para justificar una sanción retroactiva.
- AFA negó la manipulación, argumentando que sus boletines tienen numeración correlativa que "no puede ser alterada" una vez publicados.

## EL CASO DEL PASILLO: FUENTES

- Estudiantes de La Plata y el misterio del boletín 6625 - La Nación
- El boletín fantasma: no figuraba en la web oficial y se creó después del pasillo - Infocielo
- Estudiantes y el pasillo al "campeón": qué dice el boletín 6625 - El Día
- Estalla un escándalo en la AFA por un boletín con fecha adulterada - ANDigital
- ¿AFA modificó el boletín 6625 del pasillo del campeón? - Los Andes

# GESTIÓN DE INCIDENTES

- Proceso para planificar, detectar, informar, evaluar, responder, tratar y aprender de los incidentes de seguridad.



# UN EJEMPLO DE UN MAL PROCESO

## El Renaper detectó el uso indebido de una clave otorgada a un organismo público y formalizó una denuncia penal

Compartir en  
redes sociales



Publicado el miércoles 13 de octubre de 2021

El Registro Nacional de las Personas (Renaper) formalizó ayer una denuncia penal ante el Juzgado en lo Criminal y Correccional Federal N° 11 Secretaria N° 22 tras detectar que, mediante el uso de claves otorgadas a organismos públicos, en este caso el Ministerio de Salud, se filtraron imágenes como perteneciente a trámites personales realizados en el Renaper. Desde el organismo dependiente del Ministerio del Interior se confirmó que se trató de un uso indebido de usuario o robo de la clave del mismo, y que la base de datos no sufrió vulneración o filtración alguna de datos.

El sábado 9 de octubre el Renaper tomó conocimiento de que un usuario de Twitter identificado con el nombre de @aniballeaks -cuenta que fue denunciada y que actualmente se encuentra suspendida- había publicado en dicha red social las imágenes de 44 individuos, entre los cuales se encontraban funcionarios y personajes públicos de conocimiento en general.



Publicación oficial

## UN EJEMPLO DE UN MAL PROCESO - LA POSTA

- Se filtra en RAIDFORUMS (un foro sospechoso.....)
- 65000 registros disponibles como muestra de conceptp de un total de 45.387.114 supuestos en la base completa
- Los campos que ofrecen son: indice, id, idtramiteprincipal, idtramitetarjetareimpresa, ejemplar, vencimiento, emision, apellido, nombres, fechaNacimiento, cuil, calle, numero, piso, departamento, cpostal, barrio, monoblock, ciudad, municipio, provincia, pais, mensaf, foto, sexo, numeroDocumento, idciudadano.



# UN EJEMPLO DE UN MAL PROCESO - LA POSTA LINK

## SELLING Argentina Citizens Full Database 45M

by cfk - October 10, 2021 at 09:29 PM

Pages (4): 1 2 3 4 Next »

★ cfk



V.I.P User

VIP

Posts 14  
Threads 4  
Joined Sep 2021  
Reputation 20



October 10, 2021 at 09:29 PM This post was last modified: 1 hour ago by cfk. Edited 4 times in total.

#1

Database obtained from the National Population Registry of Argentina (RENAPER).  
Includes photo in base64, names, lastnames, addresses, gender, deceased or not, ID processing number, ID card information, code located on the back of the card (three lines barcode) calculated by an algorithm and all the necessary data to create a false identity card.

Total records in database: 45.387.114

Example with ID of the president Alberto Fernandez:

```
[idtramiteprincipal] => 102677495      # Processing number  
  
[idtramitetarjetareimpresa] => 102677495      # Processing number in card  
  
[ejemplar] => A      # Copy  
  
[vencimiento] => 23/03/2027      # Expiration date
```

60.000 sample records:

Quote:

[https://anonfiles.com/nc91BdP7uf/renaper\\_samples\\_json](https://anonfiles.com/nc91BdP7uf/renaper_samples_json)

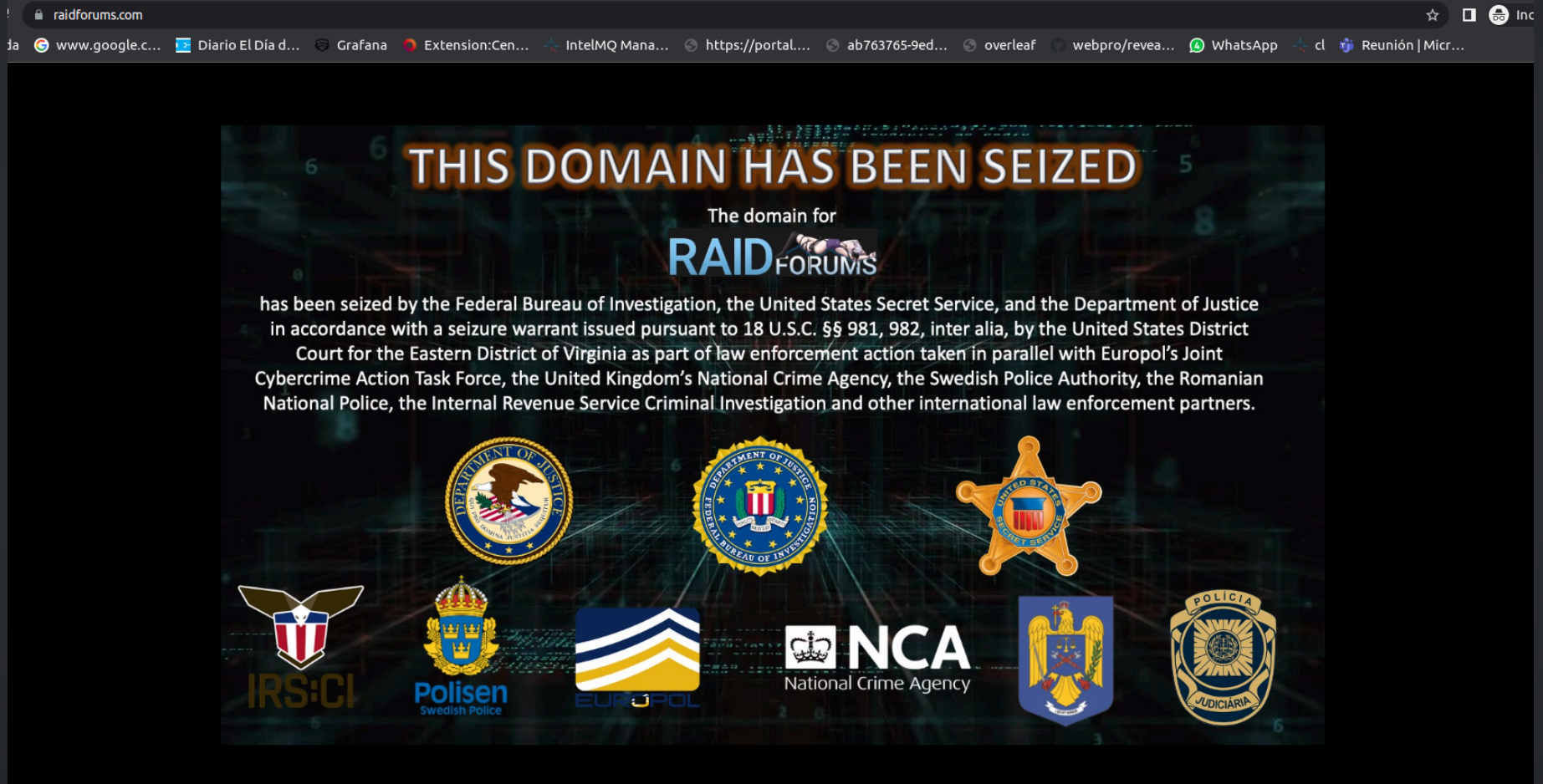
The database in SQL or JSON format.

Price is 0.29 BTC or XMR too.

For business contact me via PM or jabber: tango11@jabber.no



# MIENTRAS TANTO UN BUEN PROCESO DEBERÍA TERMINAR ASÍ



# INTRODUCCIÓN A LA FORENSIA DIGITAL - RECAPITULANDO ENTONCES

- El análisis forense en un sistema informático es una ciencia moderna que permite reconstruir lo que ha sucedido en un sistema tras un incidente de seguridad.
- Puede determinar quién, desde dónde, cómo, cuándo y qué acciones ha llevado a cabo un intruso en los sistemas afectados por un incidente de seguridad.

---

# CONCEPTOS BÁSICOS

- Una **vulnerabilidad** es una debilidad en un activo.
- Una **amenaza** es una violación potencial de la seguridad. Las amenazas sacan ventaja de las vulnerabilidades.
- Un **incidente de seguridad**, es un evento adverso que afecta los activos.
- Las amenazas sacan ventaja de las vulnerabilidades.

## EJEMPLOS CONCEPTOS

- **Vulnerabilidad:** Ventana sin rejas.
- **Amenaza:** Que alguien pueda entrar a través de esa ventana.
- **Incidente:** Concreción de una amenaza, "un ladrón entró el martes a las 17hs por la ventana y se llevó el televisor"

## EJEMPLO APLICADO

- **Vulnerabilidad:** Un software que tenga acceso a posiciones de memoria según lo que se indique en el uso.
- **Amenaza:** Que alguien manipule el software para que lea información de esa posición al usuario.
- **Incidente:** Concreción de una amenaza, "que alguien utilice el software para leer la memoria del equipo donde se esta ejecutando"

# EJEMPLO APLICADO

- **Vulnerabilidades:**
  - Falta de concientización del usuario
  - Falta de procedimientos de respuesta
  - Falta de uso de mecanismos de encriptación
- **Amenaza:**
  - Qué se comprometa la reputación de la organización a nivel local y del país a nivel regional
  - Que se filtren datos de acceso
  - Que se pierda la confidencialidad de los datos que maneja el ministerio
- **Incidente:**
  - El usuario recibe un correo adjunto y entrega sus contraseñas de acceso al Twitter y las cuentas de mail.
  - El atacante publica en la deep web la información del ministerio y sus agentes



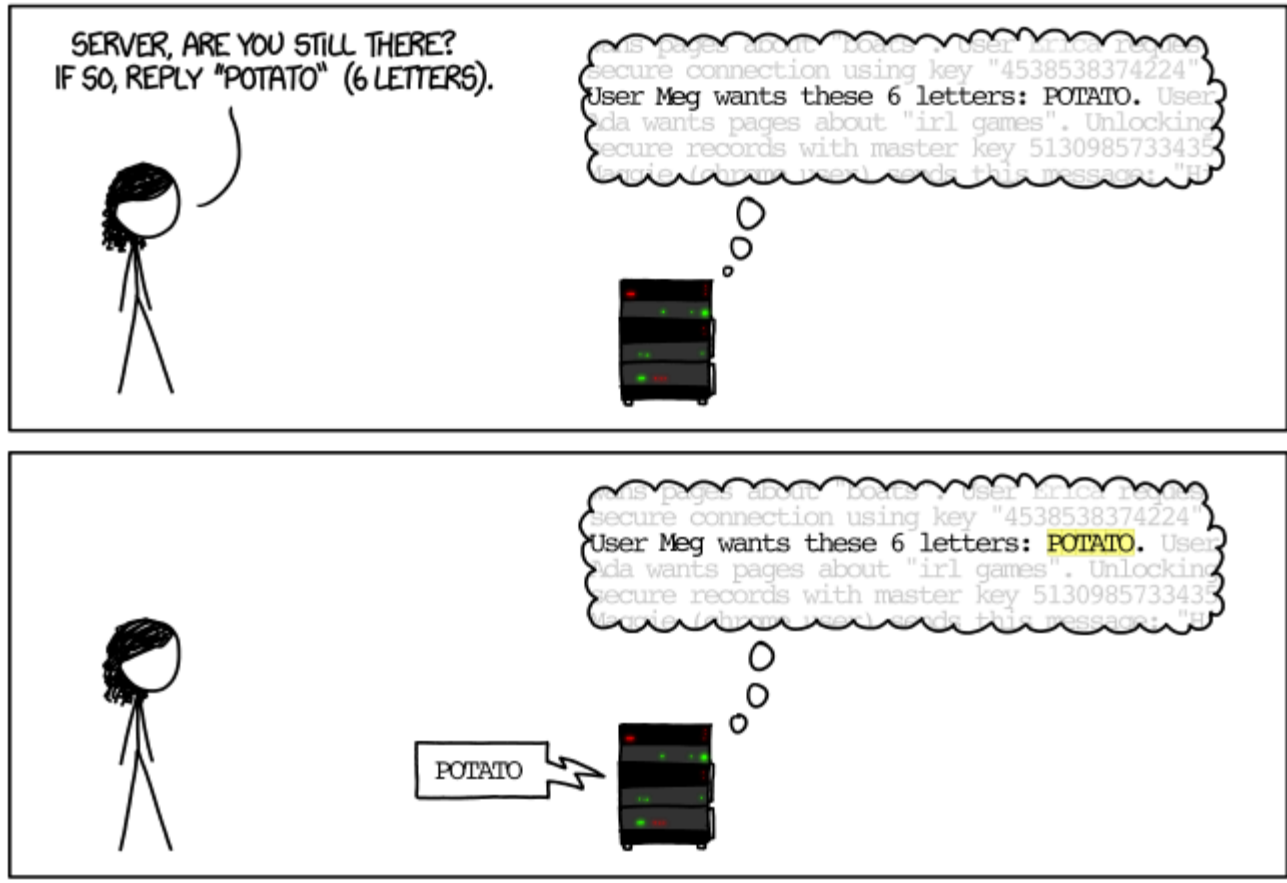
# CVE-2014-0160

- Conocido como HeartBleed
- Permitía recuperar 64Kb de memoria a partir de una vulnerabilidad en OpenSSL v 1.0.1
- La versión 1.0.1 fue publicada en el 2012 y la vulnerabilidad fue explotada recién 2 años más tarde en el 2014

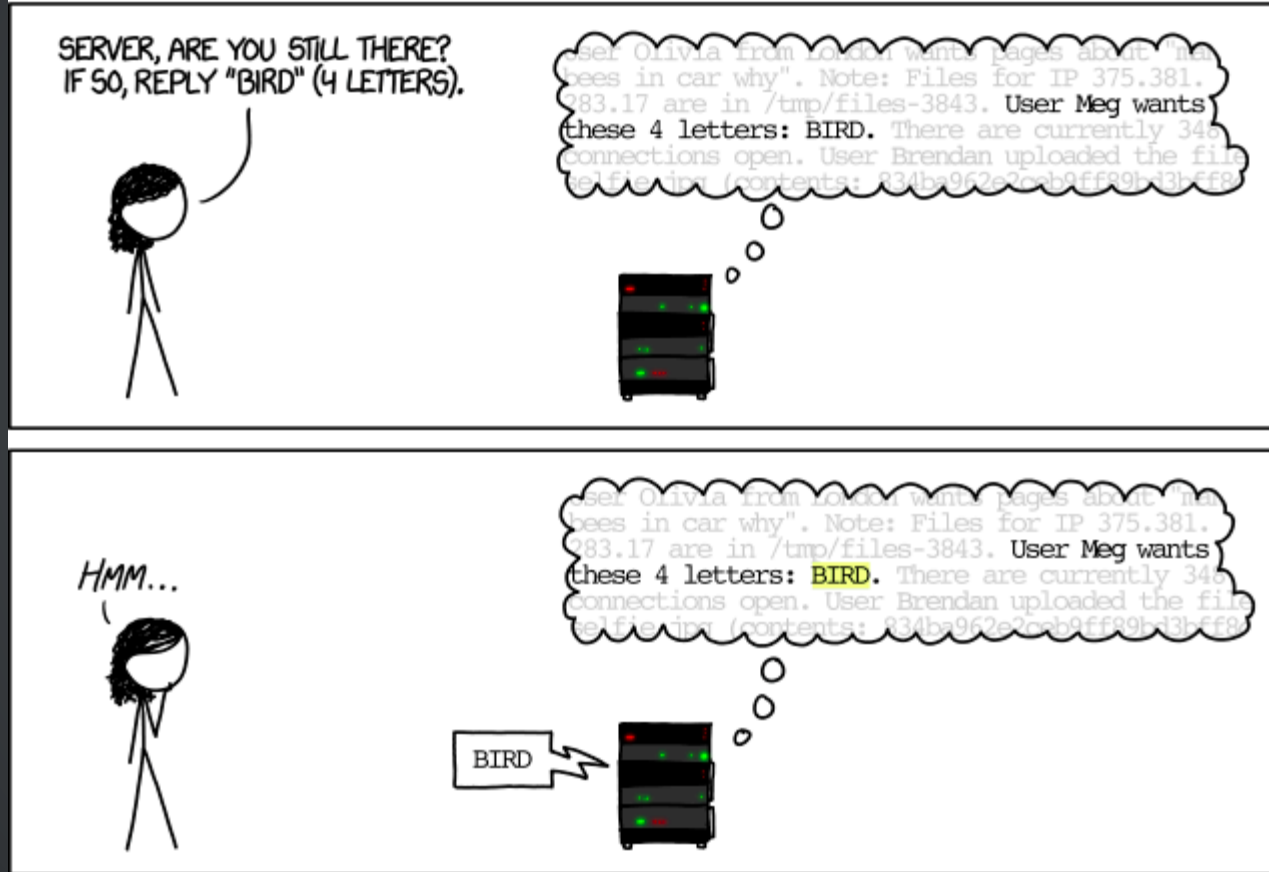


# CVE-2014-0160

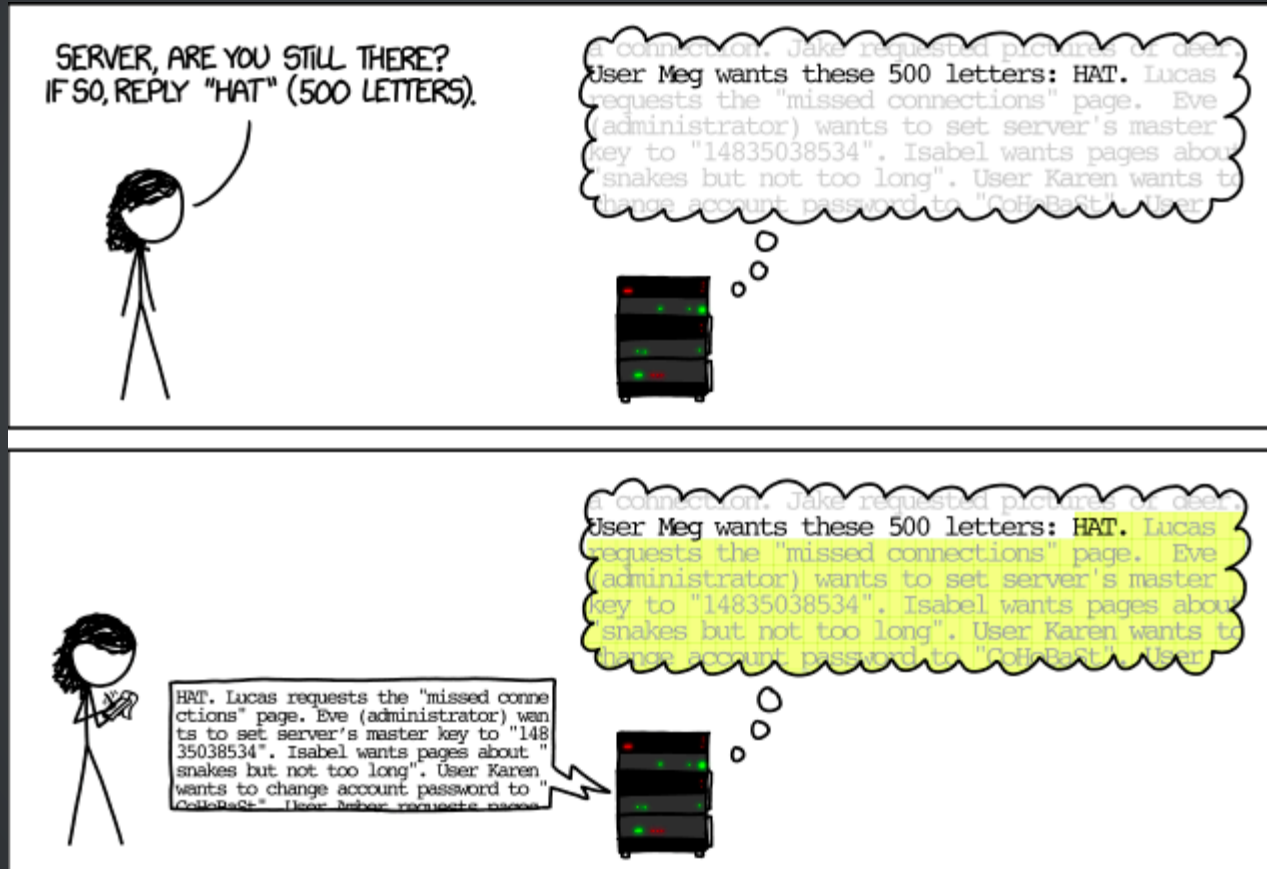
## HOW THE HEARTBLEED BUG WORKS:



# CVE-2014-0160

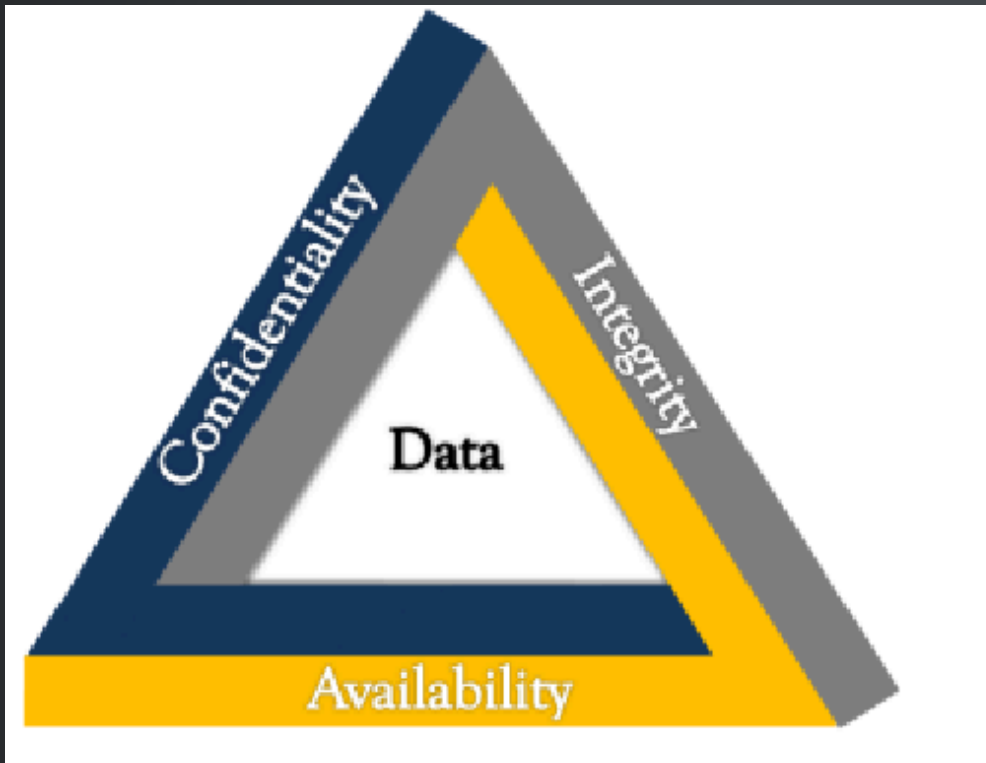


# CVE-2014-0160



# SEGURIDAD DE LA INFORMACIÓN

- La seguridad de la información es el conjunto de medidas preventivas y reactivas de las organizaciones y sistemas tecnológicos que permiten resguardar y proteger la información buscando mantener la **confidencialidad**, la **disponibilidad** e **integridad** de datos.
- Estas propiedades suelen llamarse **Triángulo CIA** por su definición en inglés.





# TRIÁNGULO CIA: CONFIDENCIALIDAD

- La **confidencialidad** es la propiedad que impide la divulgación de información a individuos, entidades o procesos no autorizados.
- Asegura el acceso a la información únicamente a aquellas personas que cuenten con la debida autorización.

# TRIÁNGULO CIA: INTEGRIDAD

- La **integridad** es la propiedad que busca mantener los datos libres de modificaciones no autorizadas.
- Es mantener con exactitud la información tal cual fue generada, sin ser manipulada ni alterada por personas o procesos no autorizados.

## TRIÁNGULO CIA: DISPONIBILIDAD

- La **disponibilidad** es la característica, cualidad o condición de la información de encontrarse a disposición de quienes deben acceder a ella, ya sean personas, procesos o aplicaciones.
- Es el acceso a la información y a los sistemas por personas autorizadas en el momento que así lo requieran.

# IFD: CONCEPTOS

- Informática forense
  - Área de la informática que es auxiliar de la justicia en los ámbitos legales correspondientes a la informática.
  - Según el FBI, es la ciencia de adquirir, preservar, obtener y presentar datos que han sido procesados electrónicamente y almacenados en un medio computacional.

# IFD: CONCEPTOS

